SECURE-RAG: Auditing Retrieval and Lightweight Adaptation for Cybersecurity Claim Verification

Tulsi Sanskrati Tomar
S24CSEU0084
Twinkle Sahu
S24CSEU0090
School of Computer Science Engineering and Technology
Bennett University, Greater Noida, India

Abstract Cybersecurity claim verification requires correct interpretation of supplied evidence and appropriate handling of missing context. This paper evaluates Qwen2.5 3B using three separate studies: a 2,367-example six-task SECURE test, 160 additional structured claims from 40 CVEs, and a matched MLX low-rank adaptation trial. Evidence-first prompting improves test KCV accuracy from 46.10% to 63.12%, but reduces performance on other task families. On additional claims, a cited-retrieval candidate achieves 68.125% accuracy against 91.25% for the full-record original arm. Forty-seven of 142 answers with matching literal citations are incorrect. A fixed 100-step adapter trained from 262 development examples improves KCV validation accuracy from 34/53 to 42/53, or 64.15% to 79.25%, relative to the same quantized MLX base. The paired source-cluster interval for the gain is [+3.57, +27.27] percentage points. The adapter returns the expected X label on 52/53 VOOD examples. These findings support a measured validation improvement and documented retrieval failure; transfer to previously unobserved CVEs remains unmeasured.

Keywords Cybersecurity · SECURE · Claim verification · LoRA · Local language models

1 Introduction

A cybersecurity assistant must distinguish a supported statement, a contradiction and an evidence gap. A correct vulnerability identifier alone does not resolve an incorrect version interval or a reversed user-interaction condition. This project studies these decisions using a small local language model and the SECURE benchmark [1]. Its central question is whether more explicit reasoning, cited retrieval or lightweight adaptation improves the actual decision under a declared evidence boundary.

The project began with retrieval and selective evidence review. Subsequent experiments expanded evaluation to all six SECURE tasks, tested a fixed retrieval candidate on additional CVEs, and trained a small adapter. These stages produce different kinds of evidence and must remain separate. The best development-pilot score cannot be substituted for test accuracy. Similarly, changing the inference runtime requires a matched baseline before attributing a gain to training.

This paper makes a bounded empirical contribution: a reproducible local evaluation with task-specific scoring, a documented failure of a cited retrieval candidate on structured CVE claims, and a matched validation comparison of a fixed low-rank adapter. The contribution is an engineering evaluation and failure analysis. LoRA, retrieval and structured generation are established techniques; this work does not claim to invent them or to surpass the original SECURE study.

The results motivate three research questions. RQ1 asks whether evidence-oriented prompting improves all task families. RQ2 asks whether a literal citation is sufficient evidence of a correct verdict. RQ3 asks whether a small supervised adapter improves claim decisions over the same quantized base model. The following sections describe related work, experimental design, implementation, measured results and limitations.

2 Background and Related Work

2.1 SECURE and the original study

Bhusal et al. introduce SECURE for cybersecurity advisory evaluation [1]. The benchmark covers Malware and Attack Extraction (MAET), Common Weakness Enumeration Extraction (CWET), Knowledge of Common Vulnerabilities (KCV), Vulnerabilities Out of Distribution (VOOD), Risk Evaluation and Reasoning (RERT), and CVSS Problem Solving (CPST). It examines multiple models and customized approaches. Its retrieve-read discussion identifies irrelevant retrieval and missing decisive information as possible failure mechanisms.

Our evaluation uses the official data at revision `a2412e8`. It adds Qwen2.5 3B experiments under a local execution protocol. Historical model scores are contextual references, not controlled comparators: model size, prompts, quantization, evaluation subsets and scoring can differ. The original study's customization experiments also mean that adding RAG or fine-tuning alone is not a defensible algorithmic novelty claim.

2.2 Retrieval and evidence support

RAG supplies non-parametric evidence to a generator [2]. Its usefulness depends on retrieving the right information and interpreting it correctly. A quote can match a source exactly while the verdict reverses the quote's meaning. We therefore measure literal citation fidelity separately from verdict accuracy. Neither is a substitute for an independently reviewed entailment annotation.

2.3 Low-rank adaptation and staged systems

LoRA freezes base weights and learns a low-rank update [3]. For a weight matrix, the effective update can be written as $W' = W + sBA$, with rank r much smaller than the matrix dimensions. The present trial uses rank eight in the final four transformer layers. Its objective is feasibility and a matched measurement, not a new adaptation algorithm. HMS-IDS [4] provides a useful example of presenting a staged cybersecurity architecture and distinct evaluation components. Its intrusion-detection tasks and datasets differ from language-model claim verification, so its reported accuracy is not a comparator here.

2.4 Task-specific evaluation in cybersecurity

CTIBench broadens evaluation to cyber threat intelligence and reports task-specific performance [5]. The distinction between its task collection and the SECURE industrial-control advisory setting matters. Correct extraction of a threat label does not imply that a model can validate a proposition against an affected-version range. Likewise, a model that handles a structured CVSS field can still produce weak risk-analysis text. The present study carries that separation through the scoring and preserves the units of the respective endpoints.

A practical consequence is that benchmark selection should follow the intended input and output. A claim verifier receives a proposition and evidence and returns a decision. A weakness-extraction system maps textual evidence to a taxonomy. A risk reasoning system produces language that may have many acceptable formulations. A score solver returns a number. The same model can be used in all four systems, but a change that benefits one output contract gives limited evidence for the others. The full benchmark results provide a direct example of that distinction.

2.5 Citation evaluation and same-model review

Gao et al. evaluate citation quality alongside answer quality in ALCE [6]. Their work motivates inspecting whether sources support generated statements. Our task is a narrower verdict problem with a source field that can be traced through a structured record. The literal quotation check makes a specific failure visible: a text string can be faithfully copied and still be semantically misused. We report it as a trace diagnostic within this benchmark's own scoring protocol.

Self-Refine uses the same model to generate feedback and revise outputs over iterations [7]. The second-pass arm in this study performs one review of a saved response and scores the resulting answer. This arm shares the original model's knowledge and weaknesses and increases total inference work. The results describe a particular review policy. The effect of an independent analyst or a separate verifier model would require an additional experimental arm.

2.6 Quantized bases and low-rank training

QLoRA demonstrates efficient adaptation by backpropagating through a frozen quantized model into low-rank parameters [8]. The Apple Silicon trial here uses the specified MLX 4-bit checkpoint and its native adapter implementation. Its experiment tests a fixed local configuration. The relevant common idea is the separation of frozen model parameters from the comparatively small trainable update. The compute results in this paper apply to the measured MLX setup.

Quantization also changes the interpretation of comparisons. Two local runtime builds can have the same nominal model name but differ in weight representation, implementation and chat serialization. A comparison between two such builds estimates their combined difference. Our adapter claim instead depends on using the same pinned MLX build and evaluating it twice, with the adapter disabled and enabled. This controls those runtime factors for the evaluation, while broader training reproducibility requires separate trials.

3 Data and Evaluation Design

3.1 Official benchmark and source grouping

The preparation pipeline checks exact SHA-256 values for all six upstream TSV files. It groups connected source URLs, shared CVE mentions in the relevant tasks, identical prompts and repeated CVSS vectors before assigning development, validation and test partitions. Historical pilot sources remain in development. This reduces direct source reuse across partitions and prevents duplicate variants from appearing as independent evidence.

The archived six-task test contains 2,367 examples: 602 MAET, 572 CWET, 282 KCV, 282 VOOD, 569 RERT and 60 CPST. It compares original prompts, evidence-first structured reasoning and self-review by the same local model. The test results are now observed. Further method selection must not treat that partition as an untouched test. The older 144-example pilot and its 93.75% pooled result are historical development evidence and are not the main result of this paper.

3.2 Additional structured CVE collection

The fresh V3 experiment contains 160 claims from 40 distinct 2025 CVEs, four claims per source. Claims concern explicit CNA CVSS v3.1 base-severity and user-interaction fields. The collection is balanced: 80 true and 80 false claims, with 80 severity and 80 user-interaction claims. Labels are generated from recorded JSON pointers and checked against the archived records. Independent human label review remains pending.

The source audit found no CVE-ID intersection with 3,108 identifiers in the six official TSV files. This is dataset-source

Table 1: Separate experimental collections. Observed validation is not a new test.

Collection	Rows	Groups	Purpose
Six-task test	2,367	By task	Prompt study
Fresh V3	160	40 CVEs	Fixed retrieval test
LoRA development	262	34	Training pool
LoRA validation	106	14	Matched comparison

separation, not proof that the pretrained model never encountered these vulnerabilities. After its results were inspected, V3 became observed development evidence for subsequent research decisions. Any later adapter evaluation on V3 would be an explicitly disclosed transfer diagnostic.

3.3 Adapter training and validation

The LoRA trial uses only development KCV and VOOD examples as training targets: 262 examples from 34 connected source groups. This pool comprises 131 examples per task. Validation contains 53 KCV and 53 VOOD examples from 14 different groups. The archived audit reports no group, CVE-ID or exact-prompt overlap between training and validation. Validation requests contain no gold label or assistant completion.

All validation KCV gold labels are binary: 20 T and 33 F. All 53 VOOD labels are X. Constant controls therefore matter. Always F reaches 62.26% KCV validation accuracy and always X reaches 100% VOOD accuracy. The latter exposes the structural limitation of using an all-X task as a general uncertainty benchmark.

3.4 Decision boundaries and units of analysis

A claim is evaluated against the evidence available to the particular arm. In KCV the record is attached to the benchmark item. A supported verdict requires the proposition to follow from that record. A contradicted verdict requires positive evidence against the proposition. An undetermined verdict is appropriate when the necessary evidence is missing. The distinction matters for a structured record. An absent affected-version entry can have a different meaning from an explicit entry that marks the version unaffected, and both have a different meaning from a record that lists a default status with exceptions.

An evidence boundary also specifies whose assertion is being evaluated. The fresh collection asks about the CNA's CVSS v3.1 assessment. If a record contains several assessments, a value from another container or another scoring version may be relevant to a general vulnerability discussion while being irrelevant to that particular claim. The experiment treats the named field and its provenance as part of the proposition. A method that retrieves the right CVE but quotes the wrong assessment has satisfied entity matching while leaving the field-level task unresolved.

An example is the unit scored in accuracy calculations. The source group is the unit used when forming partitions and estimating paired uncertainty. This distinction arises because two examples about the same CVE can depend on the same string, version list, or score. In the fresh collection, the four examples per CVE include opposite propositions about each of two fields. If one interpretation is systematically reversed, the two labels can fail together. Counting the rows is appropriate for a workload-level score. Resampling the rows independently would give a different uncertainty calculation and ignore that shared evidence.

3.5 How the three comparisons answer different questions

The six-task test holds the local model fixed and changes the prompt or review procedure. It estimates the performance of complete inference policies on a common partition. It covers both structured and open-ended outputs, so a policy that encourages longer deliberation can help one endpoint and harm another. The appropriate reporting unit is the task metric under a specified parser. A claim that a prompt is generally better would require a separate decision about the relative cost of errors across the tasks.

The fresh collection isolates a smaller family of propositions. It is valuable because the source field can be located by a pointer and the generated labels can be checked mechanically. Its balanced design also makes the behavior of a constant verdict easy to interpret. The evidence-first questions in the six-task run and the cited candidate in the fresh run have different prompts and collections. An accuracy difference between those studies cannot estimate the cost or benefit of adding citations.

The adapter comparison changes one parameterization of a fixed inference pipeline. The matched base controls for the effects of MLX, quantization, tokenizer and the short response budget. A constant-label control supplies additional context on the class distribution. The comparison between the two MLX arms estimates the observed difference produced by loading the adapter in that setting. The comparison between the adapter and a constant answer instead asks how much predictive value the system adds over a simple task-conditioned policy.

3.6 Source-grouped split procedure

The preparation code treats connectivity as transitive. For example, a shared CVE can link one KCV record to a VOOD item, while a repeated prompt can link one of those items to another source. The connected component is assigned as a unit, including rows that share no direct key with each other. This is stricter than checking duplicate prompts after a random split. It reduces the chance that a near-duplicate version of an evaluation question supplies a development example.

Grouping is deterministic for the pinned inputs and configuration. Each assignment records the example IDs and component identifier. The manifest also records per-task counts, file hashes and the upstream revision. A rerun can distinguish a split change from an upstream file change. The split membership files in the repository provide a convenient inventory, and the official records regenerate the underlying prompts and labels. Table 2 reports the resulting sample allocation.

Table 2: Counts of scorable SECURE rows by partition.

Task	Development	Validation	Test
MAET	192	278	602
CWET	223	169	572
KCV	131	53	282
VOOD	131	53	282
RERT	203	228	569
CPST	17	23	60
Total	897	804	2367

The counts show why a held-out score needs its collection name. The LoRA evaluation uses 106 validation examples drawn only from KCV and VOOD. The six-task test includes 564 examples from those two tasks and a further 1,803 examples spanning the other four. The additional fresh collection is outside those benchmark partitions. Summing the denominators would create a number with no common sampling process, while adding the numerators would mix tests of different methods.

3.7 Fresh-claim label construction

The fresh collection uses a positive proposition about each selected field and a contrasting proposition with a different field value. For severity, equality is tested against the recorded CNA category. For user interaction, the verbal claim is mapped to the v3.1 field value. The mapping reads `NONE` as exploitation without another user's participation, following the FIRST specification [9]. For claims generated from the same field, the provenance pointer stays fixed and the proposition changes. This makes it possible to trace both gold labels to one archived value.

Each record contributes two severity and two interaction examples. The resulting balance is by claim and verdict, but the underlying record values need not be balanced. The user-interaction field is NONE for 36 sources and REQUIRED for four. The data therefore let us inspect sensitivity to wording and polarity without supporting equal-precision estimates for the two source-value strata. A later collection could deliberately balance source values and add paraphrases before freezing evaluation.

The verified audit recomputed the label by traversing the archived source pointer independently of the claim generator. It also checked the 40 CVE identifiers against identifiers in the pinned upstream TSV files. These are separate safeguards. The pointer traversal tests whether the derived label follows the field. The identifier check tests for a specific kind of source overlap. Independent review would also check that the wording faithfully communicates the field, including which actor's interaction is being described and whether negation changes the intended scope.

4 Methodology and Implementation

4.1 Model-only prompt comparison

The six-task study uses Qwen2.5 3B Instruct through Ollama with Q4_K_M quantization. The original arm retains the benchmark prompt. Evidence-first asks for a concise analysis and answer in a fixed JSON schema. Self-review examines the original problem and the preceding answer, then retains or changes that answer. This is repeated inference by the same model, not an independent verifier. No external retrieval or deterministic answer rule supplies the reported six-task model-only verdicts.

The recorded experiment uses temperature 0.7, a 32,768-token requested context and a 512-token generation allowance. A declared parser scores the output without repairing it after looking at its gold label. Self-review cost includes the preceding evidence-first call.

4.2 Fixed cited-retrieval experiment

The V3 study compares full-record original prompts, top-three retrieval with JSON verdict control, and the same top-three passages with a cited candidate. The candidate asks for evidence, reasoning, confidence and a verdict. All three arms use the same installed model digest and inference settings, including a fixed generation seed. There is no extra verifier stage.

The full-record versus retrieved comparison changes selection, representation and instructions together. It therefore evaluates a complete candidate and cannot isolate one causal retrieval effect. The two top-three arms provide a more focused control for the additional citation/reasoning/confidence bundle, although those features still change together. The CVSS UI field is interpreted using the FIRST v3.1 specification [9].

4.3 Fixed MLX adapter

The adapter uses `mlx-community/Qwen2.5-3B-Instruct-4bit`, pinned at revision `4f83f8f`. Both validation arms use this same checkpoint, tokenizer, prompts, greedy decoding and 16-token output allowance. Only adapter loading differs. Comparing this result directly with the Ollama baseline would confound training with runtime and quantization changes.

Training uses MLX and MLX-LM 0.32.2 on an Apple M3 Pro with 18 GiB unified memory. The fixed configuration uses rank eight, scale 16, zero dropout, batch size one, learning rate 10^{-5}, gradient checkpointing and a 4,096-token maximum training sequence. Prompt tokens are masked from the loss. Training completions contain only T, F or X. No reasoning trace, external corpus or new generated label is added.

The prespecified run performs 100 batch-one updates with seed 20261101. This is sampling updates from a 262-example pool, not a completed epoch over every example. The final step-100 checkpoint is retained. The adapter has 1,662,976 trainable parameters, approximately 0.054% of the reported 3.086-billion-parameter model. A strict parser accepts only a normally completed single-letter response. Both validation arms return valid decisions on all examples.

4.4 Metrics and uncertainty

Classification accuracy is exact-label agreement over every example, with invalid predictions counted as errors. Binary

coverage is the fraction answered T or F. For RERT, we report the recorded ROUGE-L F1 implementation: lowercased ASCII alphanumeric tokens, no stemming, and longest-common-subsequence F-score. It measures overlap with a reference, not factual correctness. For CPST, penalized mean absolute deviation gives an invalid response the maximum error of ten. Lower is better.

For a paired comparison, each example contributes $d_i = I(\hat{y}_i^{new} = y_i) - I(\hat{y}_i^{base} = y_i)$. The observed change is $\Delta = N^{-1} \sum_i d_i$. Confidence intervals resample source groups rather than individual correlated claims. The archive uses 2,000 bootstrap draws and seed 20261031. These intervals reflect collection-level source variation under one recorded run. They omit training-seed and model-family uncertainty and are unadjusted for multiple comparisons. We do not pool accuracy, ROUGE-L and CVSS error into one score.

4.5 What each inference arm can see

The benchmark test uses an original arm, an evidence-first arm and a self-review arm. The original arm is the local model's response to the supplied benchmark prompt. Evidence-first changes the task framing and serialization of the answer. The review stage consumes a preceding response in addition to the original question. In consequence, the information available to review includes the preceding model's proposed answer, along with any mistakes in that answer. Review can repair such a mistake or anchor on it. Both types of transition are observable only when example IDs are kept paired across arms.

The fresh experiment has a different control structure. Full-record original uses the complete supplied CVE record. The format control uses three selected passages and a JSON verdict. The cited arm retains those passages and asks for a named passage, quote, comparison, confidence and verdict. The paired difference between the two passage-based arms holds passage selection fixed. It still combines several instruction changes. A narrower component experiment would need to hold the output budget and all other instructions fixed while enabling one requested field at a time.

The adapter trial evaluates a complete short-answer policy. The validation prompt supplies the same benchmark evidence to each MLX arm. The token budget is short because the completion is a label. A longer output with a valid-looking letter elsewhere fails the strict completion check. The resulting experiment measures the learned choice under that policy. It cannot recover the internal reasoning for the choice from the emitted letter. Analysis of errors is therefore based on evidence and paired verdicts rather than on a reconstructed chain of thought.

4.6 Output contracts and failure handling

The six-task benchmark includes endpoints with fundamentally different answer forms. MAET and CWET require an extraction answer that can be matched against the accepted label set. KCV and VOOD use the three-letter vocabulary, including X for undetermined. RERT is evaluated by token-overlap against a textual reference. CPST is evaluated on a numeric score in the allowed range. The recorded evaluation applies the task-specific parser to each arm. Accepting a correct-looking fragment after inspecting the gold answer would create an asymmetric opportunity to recover errors.

A valid X is an explicit model decision. A malformed or truncated answer is a parser failure. Keeping these categories distinct matters when reporting coverage. For example, a model can increase its binary answer rate by issuing more guesses, or reduce it by emitting more undetermined decisions. Either change can affect accuracy on a benchmark with different evidence conditions. Invalid answers still count in the full denominator. Otherwise a method could appear more accurate by failing to finish difficult cases.

The penalty for CPST exposes a practical consequence of serialization failures. Penalized mean absolute deviation is computed as the average absolute error over numeric responses with an error of ten for each invalid response. This makes a failed parse costly even when part of the output resembles a legitimate score. The metric therefore includes both numerical reasoning and output compliance. Reporting the invalid count beside the metric makes their relationship visible.

4.7 Evidence tracing and citation fidelity

A traceable quotation links a returned passage identifier to text in the passages supplied for that example. For the literal matching check, a cited string is compared against that named passage. The check answers whether the model quoted from its available evidence. It leaves a separate question about whether the quote supports the decision. For instance, a snippet about attack vector can be perfectly reproduced while failing to establish whether user interaction is required.

The saved diagnostics distinguish whether the selected passages contain the explicit field line and whether they contain the equivalent vector string. This is useful because the same fact can appear in two representations. An explicit line such as `userInteraction = NONE` reduces decoding effort. A vector code such as `UI:N` conveys the same value in compressed form, provided it belongs to the named assessment. Neither representation guarantees a correct interpretation of the natural-language proposition.

An operational audit can record separate outcomes for source identity, field identity, literal quotation and entailment. The first three can often be checked by deterministic code when structured evidence is available. Entailment needs a definition that accounts for negation, mixed claims and missing context. In this study the reported quote check is a surface test, and the error examples illustrate how semantic review differs. The archive contains a review sample for later annotation, with reviewer fields unfilled.

4.8 Training objective and model parity

For a sequence containing a prompt and a label completion, the training objective is the negative log likelihood of the target completion tokens. The prompt remains visible as conditioning context while its tokens are excluded from the loss. With trainable parameters θ in the adapter and frozen parameters W, the supervised objective on an observed target

sequence is

$$\mathscr{L}(\theta) = -\sum_{t \in \mathscr{M}} \log p_{W,\theta}(y_t \mid x, y_{<t}),$$

where $\mathscr{M}$ indexes the unmasked completion positions. This objective rewards the target verdict for the benchmark prompt. It provides no direct supervision of quote selection, chain-of-evidence construction, or calibration of a numeric confidence score.

Model parity requires agreement on the checkpoint, tokenizer, evaluation prompt and decoding configuration. MLX-LM loads the base weights for both arms. The trained arm additionally loads the step-100 adapter. The trial regenerates prepared JSONL files with a pinned tokenizer and checks that sequences fit the 4,096-token training cap. The recorded train and validation pools use the same format, while validation requests omit the target completion. That separation allows the evaluator to join predictions to gold labels by ID after inference.

The optimizer makes 100 batch-one updates. A 262-example pool describes the available supervision, while 100 steps describe the number of updates. These quantities answer different questions about training exposure. The reported loss includes evaluation passes during the run. The fixed step-100 policy avoids a retrospective search across checkpoints using the reported accuracy. Nevertheless, the validation collection was observed and therefore provides evidence about that collection rather than an untouched transfer test.

4.9 Paired source-level uncertainty

The bootstrap first samples groups with replacement. It then includes all paired examples from each sampled group, including repeated draws of the same group, and recomputes the difference in accuracy. In terms of group size n_g, paired correctness sum $D_g = \sum_{i \in g} d_i$, and bootstrap group multiplicity m_g, the replicate is

$$\Delta^* = \frac{\sum_g m_g D_g}{\sum_g m_g n_g}.$$

This weights examples within each replicate while respecting the grouping in the resampling procedure. A group-average estimator would instead give equal weight to every group regardless of size. Those choices agree for the fixed four-example fresh groups and can differ when group sizes vary.

The resulting interval describes variability across sampled source groups under fixed recorded predictions. It is conditional on the chosen model and procedure. A stochastic generation run could produce different verdicts for the same sources, and an adapter trained with another seed could have a different effect. These uncertainties require independent runs to estimate. Interpreting the cluster interval as a guarantee across seeds would overstate what the archive measures.

5 Results and Analysis

5.1 Six-task prompting results

Table 3 shows that no prompt is uniformly best. Evidence-first raises KCV accuracy from 46.10% to 63.12%, while self-review retains that KCV score and raises VOOD accuracy to 79.79%. MAET declines under both modifications. The RERT overlap score falls, and CPST error increases substantially. Evidence-first has 52 invalid CPST answers out of 60, which explains much of its penalized error. Parser compliance is part of the evaluated system rather than a reason to exclude difficult outputs.

5.2 The cited candidate fails the fresh test

The original full-record arm answers 146/160 correctly (91.25%). Retrieval with verdict-format control reaches 78/160 (48.75%). The cited candidate recovers to 109/160 (68.125%), but remains 23.125 percentage points below the original arm. Its paired 95% CVE-cluster interval is $[-28.125, -18.125]$ points. It fixes four original errors while breaking 41 previously correct decisions. One cited response exhausts its output budget and receives no valid verdict under the frozen scoring rule.

The result also varies by claim family. The cited arm answers 74/80 severity claims correctly, compared with 73/80 for the original. On user-interaction claims, it falls to 35/80 versus 73/80. It predicts F for all 40 true user-interaction claims. This class-specific failure would be obscured by a single headline score.

Of 159 complete binary cited answers, 142 contain a literal quotation matching a named supplied passage. Forty-seven of those 142 decisions are wrong (33.10%). Among 140 complete responses stating confidence 100, 42 are wrong (30%). Literal text matching and stated confidence therefore cannot be interpreted as correctness guarantees in this run.

For CVE-2025-41244, an archived response quotes a user-interaction field whose value is NONE, then rejects the claim that user interaction is not required. The evidence is present, but its meaning is reversed. This example illustrates semantic interpretation failure. It is an inspection of a saved response, not a completed independent human annotation. The exact source-field line is present in top-three passages for 142/160 claims. This post hoc diagnostic does not prove a causal attribution to retrieval: equivalent vector-string evidence can exist even when the explicit field line is absent.

5.3 Matched adapter validation improves KCV

The matched MLX base answers 34/53 KCV examples correctly (64.15%). The adapter answers 42/53 (79.25%), a gain of 15.09 percentage points. Eleven errors are fixed and three formerly correct answers become wrong. The paired source-cluster interval is [+3.57, +27.27] points. This is a positive result on observed validation from 14 groups, with one training seed.

True-claim recall rises from 4/20 to 13/20, while false-claim recall changes from 30/33 to 29/33. Macro-F1 over the present T/F classes rises from 0.5464 to 0.7814. The adapter reduces a strong F preference, primarily recovering true claims. The remaining 11 KCV errors comprise seven true claims rejected as F, three false claims accepted as T, and one false claim answered X. The three regressions are kcv-0005, kcv-0316 and kcv-0352.

Table 3: Recorded six-task test results. Classification values are percentages. ROUGE-L and CPST retain their own scales.

Task	Metric	*N*	Original	Evidence-first	Self-review
MAET	Accuracy (%)	602	74.92	74.09	72.26
CWET	Accuracy (%)	572	72.20	72.90	72.73
KCV	Accuracy (%)	282	46.10	63.12	63.12
VOOD	Accuracy (%)	282	54.26	70.21	79.79
RERT	ROUGE-L F1	569	0.4323	0.1614	0.2549
CPST	Penalized MAD, lower better	60	1.9400	8.8708	3.4908

Table 4: Matched MLX validation. Each task has 53 examples. Controls are fixed constant predictions.

Task	Base	Adapter	Control
KCV correct	34	42	33 (F)
KCV accuracy (%)	64.15	79.25	62.26
VOOD correct	0	52	53 (X)
VOOD accuracy (%)	0.00	98.11	100.00

VOOD changes from 53 unsupported F answers to 52 X answers and one unsupported T. This demonstrates changed behavior under these prompts. It does not establish calibrated uncertainty on arbitrary cybersecurity questions, because a constant X policy is perfect on this task. No pooled KCV/VOOD headline is used.

5.4 Compute and reproducibility

Recorded training takes 501.23 seconds (8.35 minutes), including validation-loss passes and excluding installation/model download. Inference over 106 validation examples takes 96.05 seconds for the base and 97.72 seconds for the adapter. Fixed stage order, caching and background load prevent treating this as a portable latency ratio. Maximum reported MLX inference peak allocations are 2.716 GB and 2.959 GB. These are not training memory or total system memory measurements. The final adapter occupies 6,657,883 bytes, approximately 6.35 MiB.

The V3 cited arm takes 1,324.53 seconds of measured call time versus 228.58 seconds for its original arm, a 5.79-fold observed increase. That increase buys lower overall accuracy in this run. Added reasoning or citations therefore require measurement of both benefit and cost.

The supplied archives preserve requests, responses, model/configuration identifiers and hashes. The LoRA audit checks 212 expected arm/example records, effective adapter settings, source separation, parsing and the step-100 adapter fingerprint. Tensor inspection identifies 56 finite F32 tensors in layers 32–35, with nonzero B matrices. Such checks establish archive consistency. They do not independently attest native execution, prove the absence of pretraining contamination or constitute a new inference reproduction on another machine.

5.5 Six-task transitions, coverage and scoring sensitivity

Evidence-first changes 110 KCV outcomes relative to the original arm. Seventy-nine become correct and 31 become incorrect. The net gain is 48 correct decisions out of 282, or 17.02 points. The paired source-cluster interval is $[9.78, 24.09]$ points. These transitions show that a stronger aggregate policy still fails on some examples that the original policy handles. A simple replacement policy would inherit those regressions. Routing examples between policies would require a routing rule designed on development data and evaluated separately.

Table 5: Invalid outputs by task under the archived scoring contracts.

Task	Original	Evidence-first	Self-review
MAET	0	0	0
CWET	0	0	0
KCV	0	2	0
VOOD	0	0	0
RERT	0	0	0
CPST	0	52	10

The same KCV accuracy for evidence-first and self-review does not imply identical outputs. Binary coverage rises from 60.99% with the original prompt to 73.40% with evidence-first and 75.89% with self-review. The original arm produces 110 X outputs. For KCV, an increase in binary coverage can convert some unnecessary X responses into correct verdicts while also turning uncertainty into errors. An accuracy comparison alone cannot show this operating trade-off. On VOOD, the expected response distribution differs because the task supplies no evidence for the paired claim.

CWET and RERT contain repeated prompts. The archived scorer also evaluates a reduced set retaining one row per exact prompt. This sensitivity check has 566 CWET prompts instead of 572 rows and 567 RERT prompts instead of 569 rows. The direction of the RERT loss remains in the reduced set. On CWET the differences remain small. Exact deduplication checks repetition of strings. Paraphrases with the same intent can remain distinct, and source grouping continues to matter even when every prompt string differs.

The three arms also differ in measured compute. Evidence-first uses about four times as many generated tokens as the original arm across the same test items. The self-review row in the cost table includes the evidence-first work because a review call requires the first answer. A study that charged only the review request would understate the cost of serving the complete policy from a cold start. These totals refer to saved call timings and token counters from one local run. Fixed stage order and device load limit comparisons with other machines.

For CPST, the 52 invalid evidence-first outputs contribute

Table 6: Recorded six-task costs. Self-review includes evidence-first generation.

Policy	Calls	Input tokens	Output tokens	Call time (s)
Original	2,367	810,569	29,862	1,625.57
Evidence-first	2,367	1,170,353	118,791	3,704.43
Self-review	4,734	2,613,269	272,212	7,799.42

Table 7: Fresh-claim comparisons and paired source intervals. Changes and intervals are percentage points.

Comparison	Fixed	Broke	95% interval
Original to control	4	72	$[-50.63, -34.38]$
Original to cited	4	41	$[-28.13, -18.13]$
Control to cited	39	8	$[11.88, 26.88]$

$520/60 = 8.67$ to the penalized mean by themselves. The total recorded value is 8.87. Even if every valid prediction were numerically perfect, the invalid-output contribution would remain. Self-review lowers the invalid count to ten but still yields a larger mean error than the original arm. This pattern motivates treating numeric answer extraction and scoring as distinct evaluation checkpoints. Re-running a more forgiving parser would answer a different question and should be labeled as a sensitivity analysis.

5.6 Fresh-claim outcomes at the source level

The aggregate cited score is 37 correct decisions below the full-record baseline. Four repairs offset 41 regressions. The effect is spread across the CVE collection. The cited arm is worse on 34 sources, ties on five and improves on one. With four claims per source, a single source contributes no more than four changed decisions. A high aggregate loss together with a broad source-level loss is consistent with a systematic failure of the evaluated policy on this claim design.

The passage-based control and cited arm give a different comparison. The cited arm repairs 39 examples and breaks eight relative to the control. The gain of 31 correct answers yields 19.375 points and a source-cluster interval of $[11.875, 26.875]$. The retained passages were identical across these two arms. The observed gain therefore belongs to the combined changes in requested response and reasoning fields. It does not establish that the quoted substring itself caused a correct decision. The full-record baseline remains the better complete system under this workload.

The two fields explain most of the contrast in aggregate scores. Severity changes by one net decision in favor of the cited arm. Interaction loses 38 correct decisions. Within the latter group, all 40 supported propositions become F under the cited policy, while 35 of 40 contradicted propositions remain correct. A binary system that rejects a class of supported claims can still look moderately accurate if the opposite class is common. Reporting recall alongside the aggregate score makes that failure visible.

Literal matching, field availability and verdict accuracy are different denominators. Among the 142 claims whose explicit field line is present, the cited arm answers 100 correctly and the original arm answers 129 correctly. Among the 18 claims without that line, the corresponding counts are nine and 17. Twelve of those 18 still have a vector line. Separately, the 142 matching quotations are counted among completed cited answers. The two counts of 142 arise from different checks and should never be treated as the same subset.

5.7 Inspection of archived fresh-claim responses

In the CVE-2025-41244 case the question asks whether user interaction is unnecessary in the CNA's assessment. The saved response identifies the exact source field and quotes NONE. It then reverses the field's interpretation and rejects the claim. This failure is observable at the level of a single trace. Changing retrieval depth alone would leave the cited evidence already available for that response. A deterministic field decoder could help in this narrow setting, but it would be a new policy requiring its own comparison against the original and retrieved arms.

Another saved response considers a claim that user interaction is required for CVE-2025-2747. The retrieved passages omit the explicit field line and include the vector. The response refers to the network attack vector and returns the correct F verdict. The quoted fragment concerns attack vector rather than user interaction. A correct answer therefore need not demonstrate that the stated reasoning follows from the selected evidence. This case also illustrates why audit labels should distinguish verdict agreement from evidence support.

High stated confidence does not resolve the mismatch. Forty-two of the 140 complete responses stating confidence 100 are incorrect. This is an observed error rate for a selected reported-confidence subset. A calibrated assessment would require a specified score interpretation, a calibration procedure fitted separately, and evaluation with reliability or selective-risk measures on an independent sample. The self-reported number is simply another generated field in the present prompt.

5.8 LoRA repairs and regressions

The matched KCV improvement is the balance of 11 repairs and three regressions. Nine repairs recover true claims previously rejected. The other two repairs resolve false claims previously answered X. Three false claims that the base rejected become supported under the adapter. The adapter moves the decision distribution away from F and increases the ability to accept supported claims on this validation collection, while introducing a cost on false positives.

The remaining errors include several kinds of evidence. One regression concerns a statement that Android versions

14, 13 and 12L are unaffected. The supplied record marks each of those versions affected, so the base's F agrees with the recorded label and the adapter's T does not. A second regression concerns a severity category and a third concerns whether a numeric CVSS score exceeds a threshold. These cases are useful for designing targeted tests of negation, ordered categories and numeric comparison. The adapter returns a single letter, so the archive does not establish which internal shortcut produced each error.

Seven supported KCV claims remain rejected. Their topics include product scope, vulnerability impact, exploitation conditions and mitigation. Grouping them by subject helps construct an error review queue, but subject categories alone are not causes. A fuller annotation should identify the decisive passage, verify the claim independently, and distinguish ambiguous labels from model failures. The audit retained the original labels and did not change them during scoring.

On VOOD the matched base produces F for all 53 items. The adapter emits 52 X answers and a single T for the missing-context counterpart of a KCV item. Because the corresponding KCV item is actually supported with evidence, the pair illustrates the importance of evidence availability. Correct behavior should depend on what is supplied at inference, not on the fact that a proposition is supportable in another version of the question. An all-X control remains necessary to contextualize the adapter score.

5.9 Operational meaning of the compute figures

The training time includes native validation-loss passes and excludes package installation and weight download. It measures one batch-one 100-step trial on the documented device. The reported peak allocations come from inference metadata and should be used only when describing those inference runs. The final adapter is much smaller than the base weights, but a deployed process must still load the base. An adapter-size number alone does not describe machine requirements.

The fresh cited policy increases response content and measured call time. Its total measured time of 1,324.53 seconds exceeds the full-record original arm's 228.58 seconds even though its supplied context is selected. A shorter evidence context does not necessarily yield a faster total request if the prompt asks for a longer structured response. A deployment-oriented replication should alternate arm order, include warm-up, and report latency distributions separately from total measured call time.

Figure 5 puts the direction of the observed differences on a common percentage-point scale while identifying the distinct populations. Each row is a within-study contrast. The two positive differences correspond to different interventions and baselines. Their intervals describe uncertainty within the respective collections. A comparison of which intervention works better for the same workload would require evaluating both under a common evidence boundary and scoring rule.

6 Discussion and Threats to Validity

The evidence supports a targeted conclusion: a fixed supervised adapter improves matched KCV validation, while cited retrieval can still fail on a simple source-grounded claim task. The experiments expose several distinctions that matter in practice. Finding a field differs from interpreting it. Producing an allowed letter differs from choosing the correct letter. Abstaining on an all-X task differs from calibrated selective prediction.

The findings are limited by small adaptation validation, a single seed and one model family. The fresh collection uses templates and machine-derived labels, not diverse analyst-authored questions. Its human review remains incomplete. Source groups account for some dependence, but bootstrap intervals cannot remove dataset construction bias. Different runtimes and quantization prevent direct causal comparisons between Ollama and MLX scores.

The six-task test has already been observed and informed later decisions. The LoRA validation has likewise been inspected. Neither can establish a new untouched generalization result for further tuning. The remaining prerequisite for a stronger claim is to freeze the step-100 adapter and evaluate a matched base on independently prepared, previously unobserved CVEs. That collection should mix supported, contradicted and insufficient-evidence cases with explicit evidence boundaries, while retaining raw responses. Repeated seeds and checks on the other four tasks are also needed before claiming broad improvement.

6.1 What constitutes an improvement in this setting

A useful comparison needs a specified workload and a specified error cost. For a supported vulnerability claim, returning X may delay a decision. For a false claim about affected systems, an unsupported T may trigger needless operational work. A broad accuracy metric weights these events equally. The benchmark is suitable for reporting correctness under fixed labels. A workflow that uses these decisions for triage would need to characterize the costs of false positives, false negatives and manual review separately.

The fresh results show that a trace can make an error easier to inspect without making the prediction more accurate. This distinction is important for system design. A citation feature can be evaluated for traceability, evidence support and decision quality separately. A method can improve one of those properties while harming another. A decision to ship such a feature would depend on the workload and a reviewer study measuring whether the trace actually helps people detect the remaining errors.

The LoRA result concerns a targeted change of supervision. The matched comparison supports using the adapter as a candidate for further evaluation of KCV. It leaves open whether the same training procedure helps a different model or whether the observed change persists across retraining. It also leaves open whether the adapter changes behavior on MAET, CWET, RERT or CPST, since those task families are absent from the matched trial. The benchmark prompt results indicate why measuring those outcomes separately

matters.

6.2 Construct validity of evidence and abstention

The tasks assign meaning to X through the available evidence. In a mixed workload, an X decision could be correct because the record omits a required field, the retrieved text lacks the relevant portion, or the question cannot be resolved from the evidence boundary. These mechanisms imply different remedies. Missing retrieval may be addressed by selecting additional passages. An underdetermined claim may need a different source. Incorrect interpretation may persist even with complete records.

An evaluation designed to separate these cases should mark evidence availability before scoring. It should include matched propositions with the decisive passage supplied, removed or replaced with explicit contrary evidence. Natural-language variants should preserve the same claim so that sensitivity to wording can be examined without changing the gold judgment. Reviewers should document whether a supplied passage resolves the proposition and whether a returned quote supports the predicted label. This proposed design remains separate from the recorded experiments.

The all-X VOOD reference captures an intentional boundary test. It is informative about whether a method will refrain from guessing in that setting. For general uncertainty, the useful comparison is a mixed population in which every constant policy fails on some cases. Such a design permits measuring coverage and error at the same time. An abstention mechanism can then be assessed by how it changes error at different coverage levels, with the denominator and decision threshold specified before evaluation.

6.3 Threats to causal interpretation

The six-task arms differ in reasoning instructions and response representation. The self-review policy further changes the number of calls and exposes the earlier response. The resulting difference is a policy contrast. It is possible to design narrower comparisons that isolate a structured response, a second call without access to the prior decision, or an independent verifier. None of those effects can be recovered from the existing three-arm results alone.

For the fresh comparison, full-record original and passage-based control differ in both selection and format. That means the difference of 68 in correct counts between the original and control cannot be attributed solely to removing evidence. The field-presence audit shows that many failures occur with the field supplied. It is a useful observation about the saved outputs, although the subgroup with the field present may contain easier records or a different mix of claim variants.

For the adapter trial, the matched runtime removes several confounders. Its single training run and modest number of source groups still limit precision about future performance. The effect may depend on the initialization, training example order, or benchmark-specific wording. Source-disjoint validation prevents a known category of data overlap within the prepared dataset. A closed pretrained model's exposure to public CVEs cannot be inferred from that grouping procedure.

6.4 A next evaluation that can test transfer

A stronger test can be specified before reviewing model outputs. First, freeze the adapter fingerprint, base model revision, tokenizer, prompts, decoding and strict parser. Second, build a set of independently checked propositions from records outside the development and observed validation sources. A reviewer should mark the decisive fields and evidence boundary. Include supported, contradicted and genuinely unresolved propositions across multiple field families.

Third, evaluate both MLX arms on the same IDs, retain all raw responses, and report exact completion rates and class-specific performance. Estimate paired uncertainty at the source level and state how unresolved responses and invalid generations enter the denominator. If a result is inspected and used to modify the model, record that partition as observed. Further confirmation then requires another independent collection or an explicitly labeled replication.

Finally, separate replication questions. Repeating the same training with a different seed estimates training sensitivity. Running the frozen model on another curated collection examines population transfer. Repeating inference with identical settings checks operational stability. Each answers a different question. The existing archive is useful because its pinned artifacts supply a starting configuration for all three without needing to reconstruct a favored setting from the final scores.

7 Reproduction and Audit Procedure

7.1 Preparation, run and score are separate operations

The repository [10] publishes split IDs and manifests, the source code, and the experiment protocols. Data preparation starts from the pinned SECURE revision. The benchmark preparation routine verifies the TSV hashes before building inputs and a separate label file. One completely blank CWET row is excluded and recorded. Other incomplete rows cause preparation to fail. The prepared benchmark has 4,068 scorable examples across 1,490 connected components. Compare the generated manifest with the committed reference as JSON to avoid treating indentation differences as data changes.

The historical pilot was confined to development sources when the full benchmark split was prepared. Prior holdout groups were assigned to test unless a connection to the pilot existed. The recorded preparation found no such conflict. Other groups were assigned by a hash allocation with approximate 20/20/60 proportions at the group level. Group sizes differ, so the row proportions need not match the requested group proportions. No gold label is sent with a benchmark evaluation request.

For a new six-task inference run, record the actual model digest and server version as well as the requested model name. Pin the prompt and decoding configuration before scoring. The runner writes its raw requests and responses

with example IDs and uses a sealed run configuration for resume. An existing response can be reused when the request and run identity agree. A change of prompt, model or sampling setting requires a distinct run directory. This preserves the association between reported metrics and the inference conditions that produced them.

An offline evaluation reads saved responses and applies the scoring contracts without asking the model to reconsider a prediction. Keep a fresh output directory if the original derived reports are part of an audit archive. Recomputing a metric from the same response cache tests scoring reproducibility. A new inference run tests a different property and may produce different responses, even when nominal model and decoding names match.

7.2 Audit boundaries for the fresh collection

The fresh run expects 160 examples in each of three arms. The audit checks all 480 stage/example records for missing, extra or duplicate entries. It regenerates the frozen requests and verifies response hashes. A second label check traverses the recorded source pointer in the original archived record. This verifies that the intended field yields the saved gold value. A separate check compares the 40 fresh CVE IDs with the upstream benchmark identifiers.

The score recomputation includes a strict response completion condition. One response stops at its token limit. The archived prediction stays invalid rather than being recovered from an intermediate fragment. The audit also retains diagnostic subsets such as field presence, quote match and reported confidence. Those subsets are analyzed after the primary endpoint and do not override labels or completion status.

The review material is prepared for independent annotation. An annotator would first compare the claim with the named assessment and record the decisive evidence. A separate review of a model output would check whether the selected passage is available and whether the cited text supports the decision. Blinding review to the method or original label, where feasible, would reduce confirmation bias. The present archive contains no completed independent human reviews of those samples.

7.3 Audit boundaries for the adapter trial

The adapter audit expects 106 validation inputs, each evaluated with and without the adapter. It verifies 212 archived records, checks the run and response fingerprints, and repeats strict verdict scoring. Training examples and validation requests are compared by group ID, CVE identifier and exact prompt. No validation completion appears in its request. The tokenizer check regenerates six prepared files and verifies that no example is excluded for length.

The final adapter matches the saved step-100 checkpoint. It contains 56 finite F32 tensors in the final four layers. The audit records nonzero B matrices and changes in all 56 tensors from step 50 to step 100. The declared base-model fingerprint matches the published LFS fingerprint at the pinned revision. The weight bytes are outside the response archive, so that part of the check concerns the recorded identity rather than a direct byte-for-byte check of downloaded model weights.

This audit separates three claims. The files can be internally consistent with the sealed configuration. The scorer can reproduce the reported outcome from the archived predictions. A separate lab can run the same pipeline independently and compare new outputs. The present checks establish the first two. They provide the necessary settings and tests for the third.

8 Conclusion

SECURE-RAG evaluates three interventions that are often grouped under the broad claim of better grounding. On the six-task test, evidence-first prompting improves KCV and VOOD while worsening the recorded RERT and CPST metrics. On 160 structured fresh claims, the cited retrieval candidate improves on a passage-based format control but falls below the original full-record arm. The interaction examples show that a model can quote the correct field and still reverse its meaning.

The 100-step LoRA adapter raises matched KCV validation accuracy from 64.15% to 79.25%. The improvement comes mainly from recovering supported claims, alongside three new false positives. The evidence supports a targeted validation finding. A transfer study on previously unobserved CVEs, repeated training seeds, and independent review of evidence support remain necessary to establish the scope of the improvement.

9 Scoring Examples and Diagnostic Readouts

9.1 Worked examples of claim polarity

Consider the structured value `userInteraction=NONE`. The proposition that another user's interaction is required is false under the named assessment. The proposition that another user's interaction is unnecessary is true under the same assessment. The two questions can share the retrieved passage, the source pointer, and most of their tokens. A model that treats the mention of interaction as a positive requirement could therefore get both the comparison and the polarity wrong. This is a design example based on the field definition, rather than an extra observation added to the test set.

A version claim has another failure mode. A record may identify affected versions in separate entries and specify a default for unlisted versions. The claim that every listed version is unaffected requires checking each entry. The answer cannot be derived from the presence of an unrelated default status. In the archived Android regression, the versions named in the proposition appear as affected. The task asks about those entries, regardless of any default for other versions. Inspection can verify that the prediction contradicts the record without inferring how the model arrived at the error.

A numeric threshold question differs from a category question. For a hypothetical base score of exactly 6.0, the state-

Table 8: Original-arm KCV test confusion counts. Rows are gold and columns are emitted labels.

Gold	T	F	X	Total
T	58	37	22	117
F	5	72	88	165
Total	63	109	110	282

ment that the score exceeds 6.0 is false, while a statement that it is at least 6.0 is true. A severity label is an ordered category assigned by a scoring convention. A quote containing the category HIGH cannot support the claim that the recorded category is CRITICAL. Separating equality, inequality and category comparison in an error taxonomy would make future evaluation more informative than grouping all three under numerical reasoning.

9.2 Output validity and coverage as an accounting identity

Let n_T, n_F and n_X be counts of valid emitted labels and let n_I count invalid outputs. With $N = n_T + n_F + n_X + n_I$, binary coverage is $(n_T + n_F)/N$. If c_B counts correct binary predictions and c_X counts correct X predictions, overall accuracy is $(c_B + c_X)/N$. Binary accuracy is $c_B/(n_T + n_F)$ when coverage is nonzero. These definitions explain why a method can have low overall accuracy and still answer a high share of its binary predictions correctly. The metrics answer different questions and require different denominators.

On the original KCV test, 172 of 282 outputs are binary and 130 are correct. Its binary-answer accuracy is $130/172 = 75.58\%$, while overall accuracy is $130/282 = 46.10\%$. All 110 other outputs are X and none matches the gold label in that partition. Reporting only accuracy among answered cases would omit more than a third of the evaluation questions. Reporting only overall accuracy would omit information about the method's tendency to abstain.

The original KCV test confusion counts make this explicit. Of 117 supported statements, 58 receive T, 37 receive F and 22 receive X. Of 165 contradicted statements, 72 receive F, five receive T and 88 receive X. The asymmetry shows that abstention in this arm is concentrated among contradicted propositions. The comparison does not justify carrying the same coverage interpretation over to the VOOD task, where X is the required outcome.

9.3 Interpreting changed decisions

For matched classifications, the increase in correct predictions equals the number of repairs minus the number of regressions. The overlap of correct answers is also recoverable from the base count and the number of regressions. On KCV validation, both MLX arms are correct on $34 - 3 = 31$ cases and both are wrong on $53 - (31 + 11 + 3) = 8$ cases. The two discordant cells contain the 11 repairs and three regressions. This representation makes clear that the adapter does not simply add correct outputs to a fixed base.

The corresponding fresh comparison has 105 jointly correct decisions, 41 baseline-only correct decisions, four cited-only correct decisions and ten jointly incorrect decisions. These counts use all 160 examples, including the invalid cited completion. A policy that chose the better arm after seeing the gold labels would have 150 correct answers. That upper bound describes the available disagreement pattern. It would not be an attainable measured result unless a separately evaluated decision rule could choose correctly without gold labels.

Table 9: Paired correctness outcomes. Each row uses its own evaluation collection.

Comparison	Both right	Base only	New only	Both wrong
KCV LoRA	31	3	11	8
Fresh cited	105	41	4	10

9.4 Checklist for interpreting the supplementary tables

The per-source table is useful when diagnosing generality within the fresh collection. It should be read across columns for one record before comparing columns across records. Each comparison uses the same four propositions for a CVE. An original score of four and cited score of three means a net loss of one decision. The scores alone do not reveal whether individual repairs and regressions cancel, so the paired counts remain the correct source for that question.

The validation error inventory takes the complementary view. It lists the individual adapter errors and records whether the base got the same example right. A topic such as disclosure timing tells the reader where to look in the evidence but does not establish the cause of failure. When a claim is genuinely ambiguous, the benchmark label and an independent review may disagree. Future work can preserve the original benchmark score while separately reporting agreement with adjudicated labels.

9.5 Minimum records for an independently repeated run

An independently repeated run should identify the upstream revision, split manifest, method revision, actual model digest, inference runtime, prompt and decoding options. Each response should carry the example identifier and the run identity. For an adaptation trial, retain the tokenizer revision, trainer configuration, update schedule and final adapter hash. Saving these fields makes it possible to tell whether two scores differ because of a new method, a dataset change or ordinary variation under a repeated configuration.

For scoring, retain the label join, parser status and metric version. An output can fail because a request did not complete, because a response was truncated, or because the completed string was invalid. Recording those cases separately preserves diagnostics while charging them consistently to the primary denominator. For paired comparisons, save the source-group assignment used for resampling. A confidence interval cannot be reproduced exactly from an accuracy total and an example count alone.

The principal study artifacts are lightweight compared with the runtime dependencies. The repository provides regeneration instructions for the benchmark, while the native model weights must be obtained from their original distribution. Archive checks can run on saved outputs without loading the model. This distinction lets a reviewer inspect data assignments and scoring before investing time in a full rerun.

10 Supplementary Outcome Tables

Tables 11 and 12 record the number of correct claims for each source in the fresh collection. The last column is the cited minus original count. A group-level view shows whether a small number of CVEs explains the headline difference. The observed difference extends across the majority of source groups. Each row shares a record across its four claims, so this table describes the same 160 cases as the headline experiment.

Table 13 records every remaining adapter validation error in the archive. The topic column summarizes each claim for navigation and is descriptive rather than an independent error-cause annotation. The records preserve the original gold label and the matched base decision. Comparing the two decision columns separates newly introduced errors from unresolved errors. For the missing-context case, both model arms issue an unsupported binary label, with opposite polarity.

References

[1] D. Bhusal et al., "SECURE: Benchmarking Large Language Models for Cybersecurity," in *Annual Computer Security Applications Conference (ACSAC)*, 2024. doi: 10.1109/ACSAC63791.2024.00019.

[2] P. Lewis et al., "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks," *Advances in Neural Information Processing Systems*, vol. 33, pp. 9459–9474, 2020.

[3] E. J. Hu et al., "LoRA: Low-Rank Adaptation of Large Language Models," *International Conference on Learning Representations*, 2022. arXiv:2106.09685.

[4] K. Saurabh et al., "HMS-IDS: Threat Intelligence Integration for Zero-Day Exploits and Advanced Persistent Threats in IIoT," *Arabian Journal for Science and Engineering*, vol. 50, pp. 1307–1327, 2025. doi: 10.1007/s13369-024-08935-5.

[5] M. T. Alam, D. Bhusal, L. Nguyen, and N. Rastogi, CTIBench: A Benchmark for Evaluating LLMs in Cyber Threat Intelligence, *Advances in Neural Information Processing Systems*, vol. 37, 2024.

[6] T. Gao, H. Yen, J. Yu, and D. Chen, Enabling Large Language Models to Generate Text with Citations, in *Proc. EMNLP*, 2023. doi: 10.18653/v1/2023.emnlp-main.398.

[7] A. Madaan et al., Self-Refine: Iterative Refinement with Self-Feedback, *Advances in Neural Information Processing Systems*, vol. 36, 2023.

[8] T. Dettmers, A. Pagnoni, A. Holtzman, and L. Zettlemoyer, QLoRA: Efficient Finetuning of Quantized LLMs, *Advances in Neural Information Processing Systems*, vol. 36, 2023.

[9] FIRST, "Common Vulnerability Scoring System v3.1: Specification Document," sec. 2.1.4. `https://www.first.org/cvss/v3-1/specification-document`.

[10] T. S. Tomar, "SECURE-RAG implementation and archived experiment records," project software and accompanying submission artifacts, 2026. `https://github.com/iTulsi/SECURE-RAG`.

Table 10: Configuration fields needed to distinguish the three archived evaluations. A dash indicates a setting that does not apply.

Field	Six-task prompting	Fresh structured claims	Matched adaptation
Evaluation collection	2,367 SECURE test examples	160 claims, 40 CVEs	106 KCV/VOOD validation examples
Inference stack	Ollama, Q4_K_M	Ollama, Q4_K_M	MLX-LM 0.32.2, 4-bit
Generation	Temperature 0.7	Temperature 0.7	Greedy
Generation seed	20261031	20261102	Greedy comparison
Per-call output allowance	512 tokens	512 tokens	16 tokens
Requested Ollama context	32,768	32,768	–
Training policy	–	–	Rank 8, 100 batch-one updates
Primary comparison	Task-specific metrics	Verdict accuracy	KCV validation accuracy
Uncertainty groups	Connected benchmark sources	CVE identifiers	Connected validation sources

Table 11: Fresh claim outcomes by source (1–20 of 40). Each CVE contributes four claims.

CVE	Orig.	Ctrl.	Cited	Δ
CVE-2025-0282	4	2	3	-1
CVE-2025-10035	4	2	3	-1
CVE-2025-1316	2	2	2	+0
CVE-2025-14847	3	0	2	-1
CVE-2025-20281	3	3	2	-1
CVE-2025-20333	4	2	2	-2
CVE-2025-20393	4	2	3	-1
CVE-2025-21042	4	4	3	-1
CVE-2025-21043	3	4	3	+0
CVE-2025-21479	4	3	2	-2
CVE-2025-21590	3	2	2	-1
CVE-2025-22224	4	2	3	-1
CVE-2025-22226	2	1	3	+1
CVE-2025-22457	4	2	3	-1
CVE-2025-24016	4	3	3	-1
CVE-2025-24893	4	2	3	-1
CVE-2025-25257	4	1	3	-1
CVE-2025-2746	4	0	1	-3
CVE-2025-2747	4	2	3	-1
CVE-2025-2749	4	1	3	-1

Table 12: Fresh claim outcomes by source (21–40 of 40). Each CVE contributes four claims.

CVE	Orig.	Ctrl.	Cited	Δ
CVE-2025-2775	4	3	3	-1
CVE-2025-2776	4	3	3	-1
CVE-2025-30154	4	1	3	-1
CVE-2025-31125	4	3	3	-1
CVE-2025-31324	3	3	3	+0
CVE-2025-3248	4	2	3	-1
CVE-2025-35939	3	3	2	-1
CVE-2025-3928	2	0	2	+0
CVE-2025-41244	4	1	3	-1
CVE-2025-42999	4	1	3	-1
CVE-2025-4428	3	1	3	+0
CVE-2025-5086	4	2	3	-1
CVE-2025-52691	4	2	3	-1
CVE-2025-53521	4	2	3	-1
CVE-2025-53690	4	2	3	-1
CVE-2025-54253	3	2	2	-1
CVE-2025-58034	4	1	3	-1
CVE-2025-59718	4	1	3	-1
CVE-2025-61757	4	3	3	-1
CVE-2025-6205	4	2	3	-1

Table 13: Remaining validation errors in the adapter arm, in archive order.

Example	Gold	Base	Adapter	Claim topic
kcv-0005	F	F	T	Affected versions
kcv-0021	T	F	F	Impact and scope
kcv-0073	F	X	X	Disclosure timing
kcv-0080	T	F	F	Root cause
kcv-0089	T	F	F	Remote execution
kcv-0122	T	F	F	Product scope
kcv-0165	T	F	F	Authentication
kcv-0166	T	F	F	Mitigation threshold
kcv-0316	F	F	T	Severity class
kcv-0337	T	F	F	User interaction
kcv-0352	F	F	T	Score threshold
vood-0021	X	F	T	Missing context

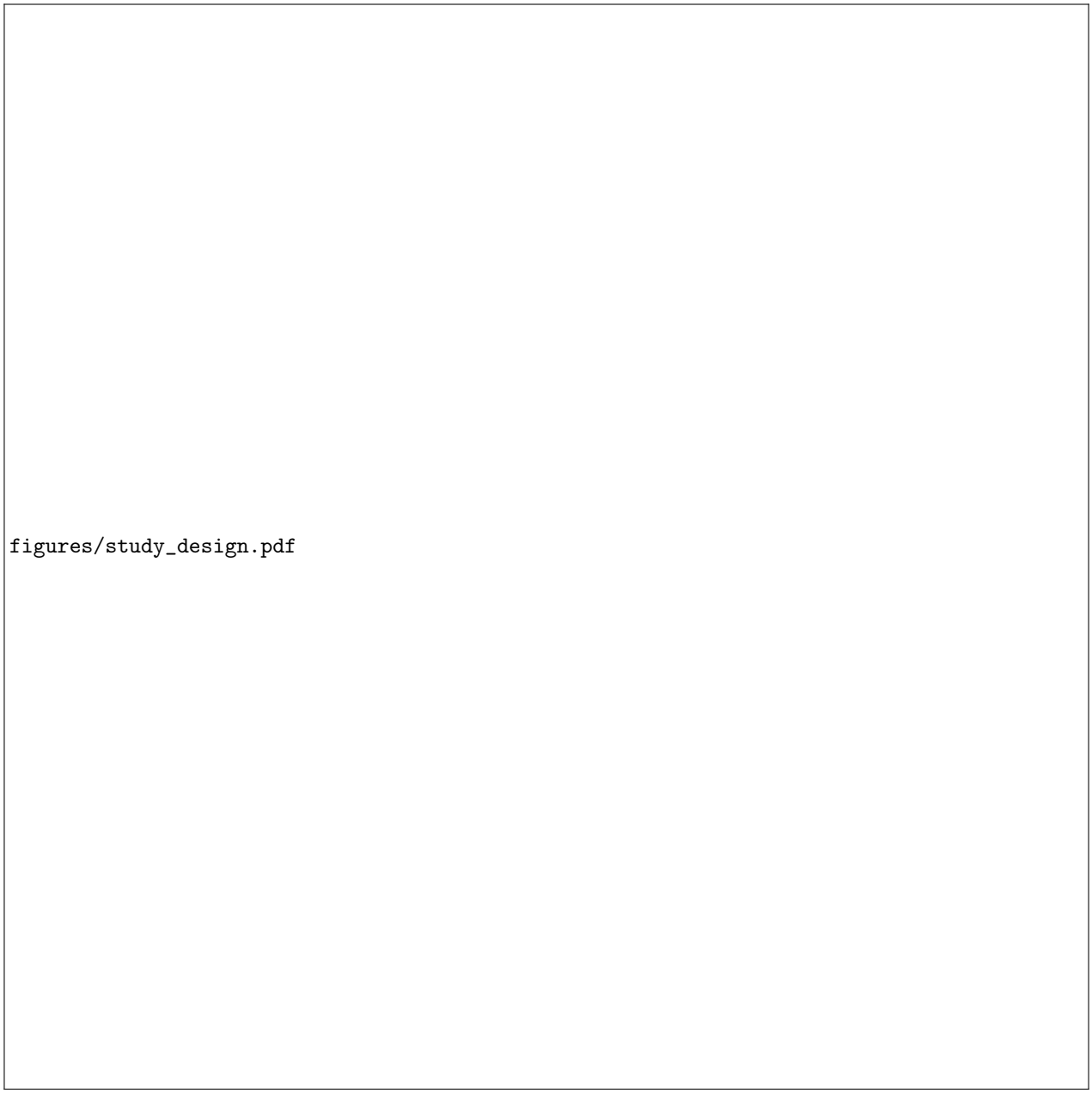


Figure 1: Study design. The three comparisons use different collections and inference configurations. No cross-runtime score is interpreted as the isolated effect of adapter training.

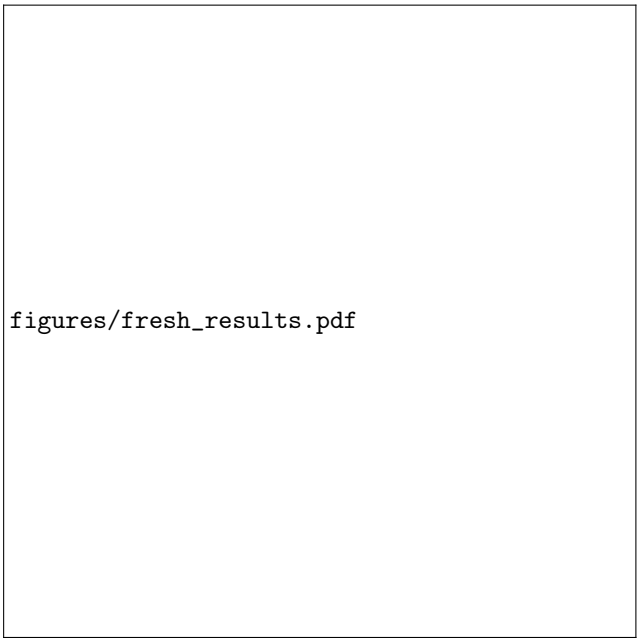


Figure 2: V3 accuracy on 160 template-generated claims. All arms share the same 40 CVE sources. The cited bundle helps its retrieval control, but loses to the full-record original arm.

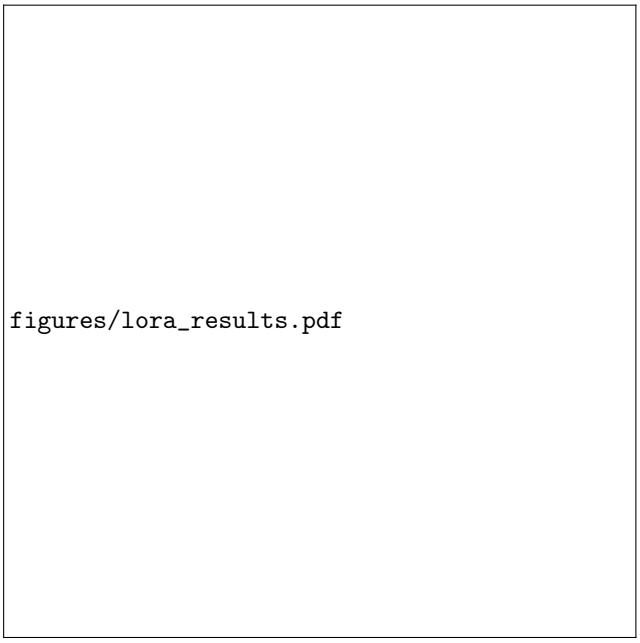


Figure 3: Separate KCV and VOOD validation results. The adapter is compared only with its matched MLX base. All-X VOOD labels limit the interpretation of the abstention score.

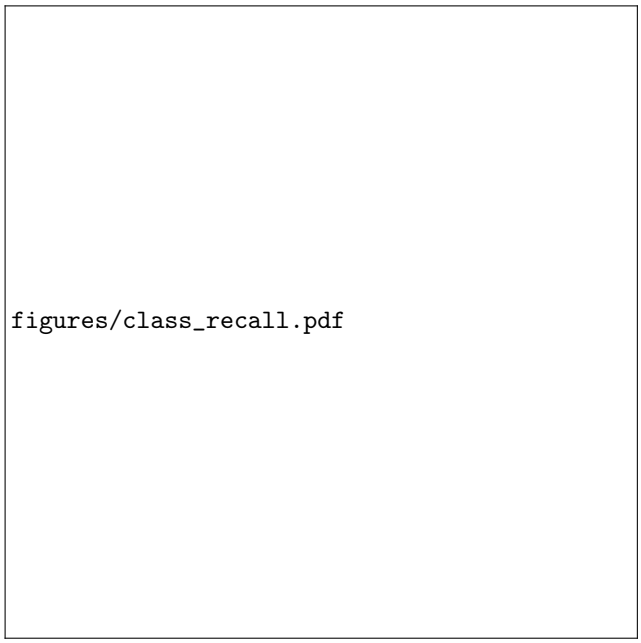


Figure 4: KCV class recall on validation. The main gain is recovery of supported claims; a small loss remains on contradicted claims.

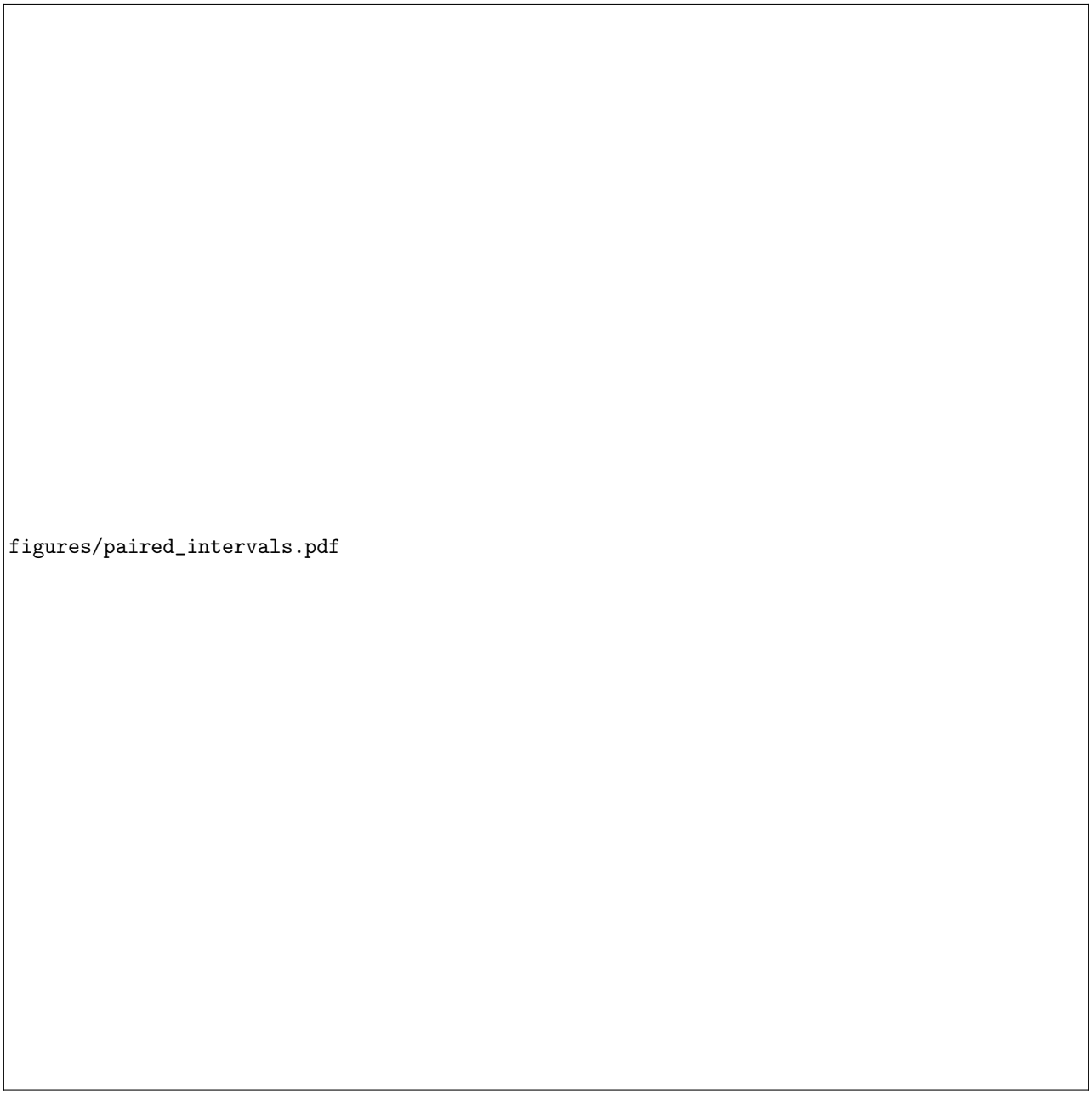


Figure 5: Observed paired accuracy changes and 95% source-cluster bootstrap intervals. The first three rows use the same fresh-claim collection. The final row uses KCV validation and a separate matched MLX configuration.